

Gap Assessment Register

Twenty representative PCI DSS v4.0.1 readiness gaps with status, severity and recommended actions.

Document ID	PCI-V2-GA-003
Prepared by	Richmond Kwadwo Sarpong
Case study	Akwaaba Retail & Online Ltd. (fictional)
Date / version	20 August 2026 / Version 2.0

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

Assessment Summary

Status labels: NIP = Not in Place; PIP = Partially in Place. Severity combines likelihood, impact and exposure of payment systems. Requirement references are representative and should be validated against the official standard during a real assessment.

Result: 1 Critical, 11 High, 8 Medium.

ID	PCI DSS ref.	Status	Risk	Fictional observation	Recommended action
G-01	1 / 1.2.4	PIP	High	CDE network and data-flow diagrams omit the CI/CD path and one store payment VLAN.	Update diagrams; reconcile to inventories and firewall rules at least every six months and after significant change.
G-02	1	PIP	Medium	Two firewall rules allow broad outbound internet access from the application subnet.	Restrict destinations and ports to documented business needs; approve and review the rules.
G-03	2 / 2.2	PIP	Medium	Secure configuration standards are incomplete for Linux hosts, WAF and POS network devices.	Approve hardening baselines, map them to builds and retain configuration-review evidence.
G-04	3	NIP	Critical	Sample debug logs contain unmasked PAN from failed checkout transactions.	Stop PAN logging immediately; securely remove retained data; test log-masking rules and document retention controls.
G-05	3	PIP	High	Account-data retention is stated in policy but automated deletion and quarterly verification are absent.	Implement retention jobs, exception reporting and evidence of quarterly deletion verification.
G-06	4 / 4.2	PIP	Medium	One legacy POS support connection permits an obsolete TLS configuration.	Disable weak protocols and ciphers; retest endpoints and retain scanner evidence.
G-07	5	PIP	High	Anti-malware coverage and behavioral monitoring are inconsistent across CDE Linux and admin systems.	Deploy centrally managed protection or documented risk-based controls; monitor health and alerts.
G-08	6 / 6.3.3	NIP	High	Two critical web-platform security updates remained open for more than one month.	Apply critical patches, investigate delay causes and enforce vulnerability-to-patch service levels.
G-09	6	PIP	Medium	Secure coding training is not recorded for all developers who change checkout code.	Complete annual role-based training and retain attendance plus competency evidence.
G-10	6 / 6.4.3	NIP	High	Payment-page scripts lack a complete inventory, documented authorization and integrity justification.	Inventory and authorize scripts; justify each script; implement integrity controls and controlled change approval.
G-11	7 / 7.2.4	PIP	Medium	Access reviews exclude two service accounts and one third-party support account.	Review all user, service and vendor access; confirm business need, privilege and owner approval.
G-12	8 / 8.4.2	NIP	High	MFA is not enforced for all non-console access into the CDE.	Enforce MFA for all applicable CDE access, remove bypasses and test authentication logs.
G-13	9	PIP	Medium	Visitor-log completeness and quarterly POS-device inspection evidence are inconsistent at one store.	Standardize visitor records, device inventory, inspection method, staff training and exception escalation.
G-14	10 / 10.4	PIP	High	Daily review is limited to firewall alerts; application, identity and database security events are not consistently reviewed.	Define critical log sources, SIEM use cases, daily review evidence and documented follow-up.
G-15	10	NIP	High	Only 90 days of readily available audit logs are retained for two CDE systems.	Implement the required retention period, protect logs from alteration and validate retrieval.
G-16	11	NIP	High	External scans were performed by an internal scanner rather than an Approved Scanning Vendor.	Engage an ASV, remediate failures and retain passing quarterly scan reports.
G-17	11	PIP	Medium	The penetration test covers the web application but not segmentation controls or the store payment network.	Expand annual and significant-change testing to CDE boundaries and segmentation; retest findings.
G-18	11 / 11.6.1	NIP	High	No automated mechanism detects unauthorized changes to payment pages and security-impacting HTTP headers.	Deploy change/tamper detection, define alert response and test at the required frequency.

ID	PCI DSS ref.	Status	Risk	Fictional observation	Recommended action
G-19	12 / 12.3.1	NIP	Medium	Targeted risk analyses are missing for activities whose frequencies are entity-defined.	Document asset, threat, likelihood, impact and justified frequency; review analyses at least annually and after change.
G-20	12	PIP	High	The incident response plan has not been tested for payment-data compromise and third-party escalation.	Run a tabletop exercise, validate contacts and evidence preservation, and track lessons to closure.

Closure Standard

A finding should not be closed on ticket status alone. Closure requires implemented control design, operating evidence across the scoped population, independent validation or retesting, and updated policies, inventories, diagrams or procedures where relevant.

Acronyms and Definitions

Document-specific reference glossary for **Gap Assessment**. Definitions are written in plain language for recruiters, reviewers and non-specialist readers.

Acronym	Full meaning and explanation
AOC	Attestation of Compliance A formal declaration that applicable PCI DSS requirements have been assessed.
ASV	Approved Scanning Vendor A company approved by the PCI SSC to perform external vulnerability scanning services.
CDE	Cardholder Data Environment The people, processes and technologies that store, process or transmit cardholder data, or can affect its security.
CHD	Cardholder Data At minimum, the primary account number; it may also include the cardholder name, expiration date or service code.
MFA	Multi-Factor Authentication Authentication using at least two different factor types before access is granted.
NTP	Network Time Protocol A protocol used to synchronize system clocks for reliable logs and investigations.
PAN	Primary Account Number The payment card number that identifies the issuer and cardholder account.
PCI DSS	Payment Card Industry Data Security Standard The global security standard for protecting payment account data.
POA&M;	Plan of Action and Milestones A tracked plan describing corrective actions, ownership, deadlines and closure evidence.
QSA	Qualified Security Assessor A PCI SSC-qualified organization or individual that performs PCI DSS assessments.
RBAC	Role-Based Access Control Access permissions assigned according to approved job roles and responsibilities.
ROC	Report on Compliance A detailed report documenting the results of a PCI DSS assessment.
SAQ	Self-Assessment Questionnaire A validation tool for eligible entities to document PCI DSS self-assessment results.
TPSP	Third-Party Service Provider An external provider whose services store, process, transmit or can affect the security of account data.

Portfolio note: This glossary supports a fictional PCI DSS v4.0.1 readiness case study and does not represent a formal compliance determination.